

The Growing Threat of Credential Stuffing and 6 Ways to Defend Your Organization

What Is Credential Stuffing?

Credential stuffing is a cyber attack technique in which attackers employ automated tools to test stolen login credentials across numerous websites and applications. This approach capitalizes on the fact that many users reuse passwords across various platforms, making it simpler for hackers to obtain unauthorized access to multiple accounts.

The number of data breaches has risen significantly in recent years, resulting in a vast amount of compromised credentials available on the dark web. Cybercriminals exploit this situation by using bots and scripts specifically designed for credential stuffing attacks.

This is part of a series of articles about [cybersecurity attacks](#)

The Growing Threat of Credential Stuffing

Credential stuffing has become an increasingly favored attack method for cybercriminals, mainly due to its ease of execution and high success rate. Several factors contribute to the increase in credential stuffing attacks:

- 1. More data breaches:** The frequency and scope of data breaches have dramatically increased in recent years, leading to a massive amount of stolen credentials accessible for purchase or free download on dark web marketplaces and forums. This wealth of compromised login information makes it simpler for attackers to launch large-scale credential stuffing campaigns.
- 2. Password reuse:** Many users persist in reusing their passwords across multiple online accounts, rendering them more susceptible to credential stuffing attacks. Research shows that most individuals use identical passwords for multiple accounts, leaving them exposed if one account is hacked.

3. **Advanced automation tools:** Attackers now have access to sophisticated automation tools, such as bots and scripts, specifically designed for executing credential stuffing attacks on a large scale. These tools can quickly test thousands or even millions of username/password combinations against targeted websites or applications within a short time.
4. **Insufficient Multi-Factor Authentication (MFA):** Despite the proven effectiveness of MFA in thwarting unauthorized access, many organizations still do not implement MFA across their digital assets. According to a Microsoft Identity team [survey](#), only 11% of enterprise users enabled MFA, leaving the majority vulnerable to credential stuffing attacks.

Low risk: Because attackers use legitimate login credentials obtained from previous breaches, it becomes more difficult for security systems and professionals to detect and block such attacks compared to traditional brute force attempts.

The Credential Stuffing Attack Process

Step 1: Obtaining Stolen Credentials

The initial step in a credential stuffing attack involves acquiring large sets of compromised usernames and passwords. Cybercriminals typically obtain these datasets from various sources, such as data breaches, phishing campaigns, or even buying them on dark web marketplaces.

Step 2: Setting Up Automation Tools

Attackers then use specialized software or scripts, known as "credential stuffers," to automate the process of testing stolen credentials against targeted websites. Some popular open-source tools include OpenBullet, SentryMBA, and Snipr. These tools can be customized with specific configurations aimed at bypassing security measures like CAPTCHAs or IP blocking.

Step 3: Initiating the Attack

The attacker launches the credential stuffing process using their chosen tool, which sends multiple login attempts simultaneously at high speeds to target websites or applications. If unauthorized access is obtained, the attacker may use the compromised accounts for various malicious purposes, such as identity theft, financial fraud, or spreading malware.

Step 4: Exploiting Compromised Accounts

Once an account has been breached, attackers may opt to sell access to it on underground forums or use it for further attacks. For instance, they might attempt to take over other user accounts linked with the same email address by exploiting password reset features

Credential Stuffing vs. Brute Force Attacks

Although both credential stuffing and brute force attacks aim to gain unauthorized access to user accounts, they differ in their methods and strategies. Understanding these differences is essential for security professionals, ethical hackers, and DevSecOps teams working on [application security](#).

In a **credential stuffing attack**, cybercriminals use large sets of stolen or leaked credentials (usernames and passwords) from previous data breaches. They then attempt to log into various websites using these known combinations, hoping that users have reused the same credentials across multiple platforms.

In contrast, a **brute force attack** involves systematically trying all possible username-password combinations until the correct one is found. This method can be time-consuming but may eventually succeed if the targeted account has weak or easily guessable login information.

Credential stuffing attacks are relatively easier to execute than brute force attacks because they rely on already compromised data rather than generating every possible combination. As a result, credential stuffing tends to have higher success rates since many users reuse their passwords across different platforms.

On the other hand, brute force attacks require more computational power due to the sheer number of attempts needed before finding valid login details. These types of attacks also face additional challenges like rate limiting mechanisms implemented by websites, which slow down or block repeated failed login attempts.

6 Ways to Mitigate Credential Stuffing Threats

As the frequency of credential stuffing attacks increases, it's vital for security experts, ethical hackers, and DevSecOps teams to adopt best practices that minimize risks and avert future occurrences.

1. Enable Multi-Factor Authentication (MFA)

MFA requires users to supply extra verification besides their username and password, considerably reducing the chances of a successful credential stuffing attack. By incorporating MFA for all user accounts, you significantly lower the odds of a successful

credential stuffing attack since adversaries would require access to multiple factors to obtain unauthorized entry.

2. Strengthen Password Policies and Educate Users

Introducing robust password policies, such as requiring a minimum length or mandating the use of special characters, helps guarantee that users generate complex passwords less prone to brute force assaults. Furthermore, offering regular user training on proper password practices, like employing unique passwords for distinct accounts, can decrease the risks caused by data breaches involving exposed credentials.

3. Develop a Password Blacklist

Prevent the use of common or easily predictable passwords by generating a blacklist of forbidden words or expressions. Implementing this strategy stops users from selecting weak passwords, which are more susceptible during credential stuffing attempts.

4. Utilize CAPTCHA Technology

CAPTCHA technology obliges users to finish tasks that only humans can perform before allowing access, thus blocking automated bots utilized in credential stuffing attacks from entering your system. Incorporating CAPTCHAs on login pages can considerably lower the likelihood of such attacks.

5. Observe and Examine Login Attempts

By carefully observing login attempts, you can pinpoint patterns that suggest credential stuffing. For instance, multiple unsuccessful logins from a single IP address or rapid series of login attempts could indicate an ongoing assault. Deploying Security Information and Event Management (SIEM) tools can assist in identifying these patterns and notifying your security team to take suitable measures.

6. Implement Rate Limiting

Rate limiting specifies the number of requests a user or IP address is allowed to make within a specific time period. By enforcing rate limiting on authentication endpoints, you hinder automated bots from executing numerous login attempts in quick succession—thus decreasing the chances of successful credential stuffing attacks.

Credential Stuffing Prevention with HackerOne

The HackerOne Attack Resistance Platform is an innovative way to truly prevent attacks like credential stuffing before they can occur. How? By including human security experts to continuously assess the attack surface for the flaws that bad actors target. With HackerOne, organizations are able to outsmart cybercriminals, extend the reach of their security teams and reduce their exposure to threats.

[Learn more about the HackerOne Attack Resistance Platform](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

